

Universidad del Desarrollo
Seguridad y Protección de Datos

Hito 1

Inventario y Clasificación de Datos Personales

Caso elegido: MTG Companion — app de intercambio y compraventa de cartas de
Magic: The Gathering

Grupo: MTG Companion

Integrantes: Vicente Fuentes · Tomás Rodríguez · Tomás Solano

Fecha: 5 de octubre de 2026

2. Índice

1. Portada	1
2. Índice	2
3. Introducción	3
4. Inventario de datos personales	4
5. Mapa de flujos de datos	6
6. Clasificación por sensibilidad	8
7. Finalidad y base de licitud	9
8. Conclusiones	10
9. Referencias	11
10. Anexos	12
Anexo A — Actividad N°1: Mapeo de actores, datos y riesgos CIA	12
Anexo B — Actividad N°2: Cifrado, hashing y tokenización	15

3. Introducción

MTG Companion es una aplicación móvil (Android) para jugadores de *Magic: The Gathering*. Permite escanear una carta para identificarla y estimar su condición junto a su precio; guardarla en una colección personal (la "Bóveda"); publicarla en un mercado entre jugadores (el "Bazaar") con búsqueda por cercanía; recibir ofertas; pagar con MercadoPago o en efectivo; y confirmar la entrega con un código QR firmado. Incluye segundo factor de autenticación (2FA) y una ruleta para la obtención de cupones.

Cabe destacar que **el reconocimiento de cartas ocurre íntegramente en el teléfono** (OCR y cuatro modelos de IA locales), por lo que las imágenes de la cámara no llegan al servidor salvo que el usuario publique una foto. El servidor (API NestJS con PostgreSQL) solo guarda lo que el usuario decide registrar y se aloja en Amazon Web Services (AWS), región us-east-1 (Estados Unidos).

Actores que participan:

- **Jugador (titular):** vendedor, comprador o postor según la acción; puede ser menor de edad (sección 6).
- **MTG Companion (responsable):** el equipo que opera la app y el servidor y decide los fines y los medios del tratamiento.
- **Administrador del sistema:** miembro del equipo de desarrollo con acceso a la nube y a sus secretos.
- **Amazon Web Services (encargado):** aloja el servidor, base de datos, fotos (S3) y secretos.
- **Proveedor de correo (encargado):** envía bienvenidas y comprobantes de pago.
- **MercadoPago (tercero, responsable propio):** procesa los pagos; la tarjeta se ingresa en su plataforma.
- **Otros jugadores (destinatarios):** ven nombre visible, cartas publicadas con foto, ofertas y distancia.
- **Scryfall (API externa de catálogo):** la app **no se conecta a ella**; el catálogo se importa sin conexión a la base propia, así que no recibe datos ni la IP de los jugadores.

Marco normativo. Hoy rige la Ley 19.628; la Ley 21.719 (D.O. 13-12-2024) reemplaza buena parte de su texto desde el 1 de diciembre de 2026 (Ley 21.719, artículo primero transitorio). Como la app operará bajo la nueva norma, se analiza con el texto de la Ley 19.628 **modificado por la Ley 21.719**. Salvo que se indique "texto vigente", "Ley 19.628, art. X" se refiere a su texto modificado por la Ley 21.719 (la numeración cambia: el art. 12 de la Ley 19.628 trata del acceso en el texto vigente y del consentimiento en el nuevo).

4. Inventario de datos personales

Construido a partir del esquema real de la base de datos, el código de la app y sus integraciones. Las bases de licitud se justifican en la sección 7.

Categoría de dato	Dato específico	Fuente	Ubicación de almacenamiento	Finalidad	Base de licitud	Con quién se comparte	Plazo de conservación
Identificación	Correo y nombre visible	Registro	users (PostgreSQL)	Cuenta, login, correos; identificarse ante la contraparte	Contrato (Ley 19.628, art. 13 c)	Email: proveedor de correo, AWS. Nombre: jugadores	Vigencia de la cuenta (*)
Credenciales	Contraseña y tokens de sesión	Registro y login	users, refresh_tokens; teléfono	Autenticar y mantener la sesión	Contrato (Ley 19.628, art. 13 c)	No se comparte	Cuenta (*); tokens: 15 min / 30 días (*)
Credenciales	Secreto 2FA, cifrado	Servidor, al activar 2FA	user_settings	Verificar el segundo factor	Consentimiento (Ley 19.628, art. 12)	No se comparte	Hasta desactivar 2FA (se borra)
Preferencias	Idioma, tema, aviso por correo (aún sin efecto)	Usuario	user_settings	Personalizar la app	Contrato (Ley 19.628, art. 13 c)	No se comparte	Vigencia de la cuenta (*)
Geolocalización	Ubicación (cifrada) de quien abre el Bazaar con sesión	GPS, con permiso	user_settings; la de búsqueda no se guarda	Distancia a cada vendedor	Consentimiento (Ley 19.628, arts. 12 y 16 sexies)	No; solo se muestra la distancia	Hasta revocar o 30 días sin uso (*)

Categoría de dato	Dato específico	Fuente	Ubicación de almacenamiento	Finalidad	Base de licitud	Con quién se comparte	Plazo de conservación
Imagen	Fotogramas del escáner	Cámara	Memoria del teléfono	Identificar la carta (IA local)	No aplica: el responsable no los recolecta (sección 7)	No se comparte	No se conserva
Imagen	Foto para publicar	Cámara (foto manual)	Teléfono (temporal); S3 al publicar	Mostrar el estado de la carta	Contrato (Ley 19.628, art. 13 c)	Compradores (enlace temporal); AWS	Teléfono: temporal; S3: con la publicación
Patrimonio	Colección, mazos y ofertas	Usuario e IA local	cards, decks, offers	Organizar, publicar y ofertar	Contrato (Ley 19.628, art. 13 c)	Publicadas: visibles; ofertas: vendedor	Cuenta o publicación (*)
Financiero	Transacciones y referencia de pago	Servidor; MercadoPago	transactions	Registrar compraventa y pago	Contrato y obligación legal (**) (Ley 19.628, art. 13 c y b; DL 830)	Contraparte; MercadoPago; correo	MercadoPago: 6 años (*) (**); efectivo: cuenta (*)
Financiero	Datos de tarjeta	MercadoPago	Solo MercadoPago	Pagar	Contrato del usuario con MercadoPago	MercadoPago (responsable propio)	No se guardan
Beneficios	Cupones	Ruleta de premios	coupons	Promociones	Contrato (Ley 19.628, art. 13 c)	No se comparte	Hasta vencer o, si se canjeó, como la transacción (*)

Categoría de dato	Dato específico	Fuente	Ubicación de almacenamiento	Finalidad	Base de licitud	Con quién se comparte	Plazo de conservación
Técnico	Dirección IP	Conexión	No se registra	Entregar el servicio	Interés legítimo (Ley 19.628, art. 13 d; sección 7)	AWS	No se conserva

(*) Política del grupo que el sistema **aún no aplica**: hoy se conserva indefinidamente (sección 8). (**) A confirmar (sección 7, F4).

5. Mapa de flujos de datos

Cuatro flujos principales: dónde nace cada dato, qué sistema lo procesa y dónde termina. La tabla detalla cada transformación y la Figura 1 los muestra en conjunto.

Flujo	Origen	Actor / sistema	Destino	Transformación
F1 Registro y autenticación	Formulario de registro / login	Backend (usuarios y autenticación)	PostgreSQL (users, user_settings, refresh_tokens); proveedor de correo	Contraseña → hash bcrypt; secreto 2FA → AES-256-GCM; tokens firmados (HMAC) y renovación como hash SHA-256; email → bienvenida.
F2 Escaneo y publicación	Cámara del teléfono	IA en el teléfono; luego backend	Teléfono; al publicar: PostgreSQL (cards) y S3	Fotogramas: se procesan y descartan en memoria. Foto manual: archivo temporal; al publicar sube a un bucket privado con enlace firmado.
F3 Búsqueda con ubicación	GPS del teléfono, con permiso	Backend (usuarios y cartas)	PostgreSQL (user_settings); a otros, solo la distancia	La ubicación de todo jugador con sesión que abre el Bazaar se cifra al guardarla; en una búsqueda se descifra en memoria para calcular la distancia y la respuesta lleva solo km.

Flujo	Origen	Actor / sistema	Destino	Transformación
F4 Compraventa y pago	Compra u oferta del jugador	Backend (transacciones, pagos) y MercadoPago	PostgreSQL (transactions); MercadoPago; correo; contraparte	A MercadoPago: id, título y monto; la tarjeta queda en MercadoPago (se guarda solo la referencia). Aviso de pago con firma HMAC; comprobante a ambas partes; entrega con QR firmado (3 min).

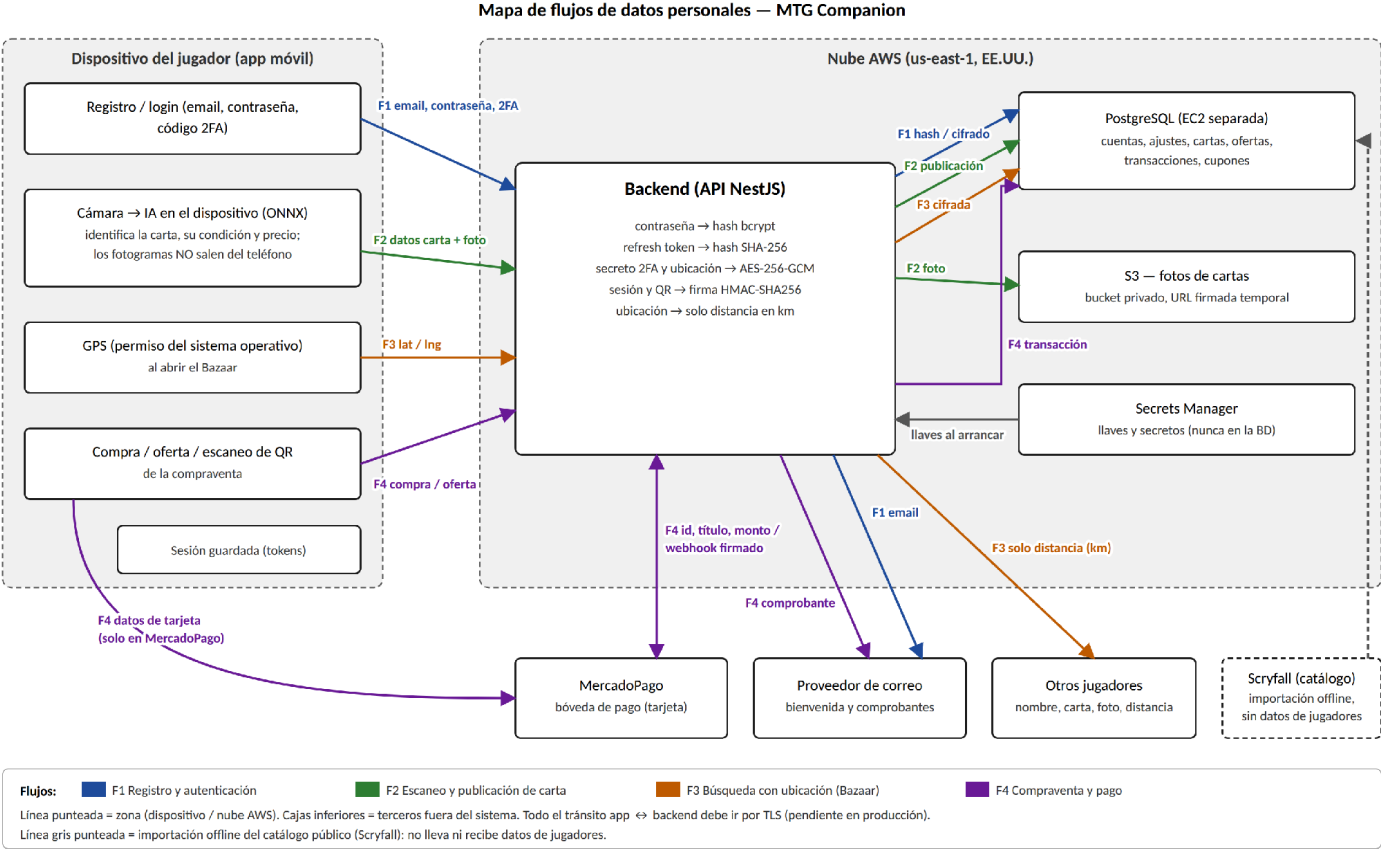


Figura 1. Mapa de flujos de datos personales de MTG Companion (F1 a F4).

Scryfall no participa en estos flujos: el catálogo de cartas se importa sin conexión y no lleva datos de jugadores (ver Introducción).

6. Clasificación por sensibilidad

Dato personal: información vinculada a una persona identificada o identificable (Ley 19.628, art. 2 letra f). **Sensible:** la que revela, entre otros, situación socioeconómica, salud o datos biométricos (Ley 19.628, art. 2 letra g). **Categorías especiales:** biométricos, menores y geolocalización (Ley 19.628, arts. 16 ter, 16 quáter y 16 sexies).

Dato	Clasificación	Justificación
Correo y nombre visible	Personal	Identifican al titular (Ley 19.628, art. 2 f); no revelan su intimidad.
Contraseña, secreto 2FA, tokens	Personal (crítico)	No están en la Ley 19.628, art. 2 g, pero permiten suplantar al jugador: máxima protección (Ley 19.628, art. 14 quinquies).
Preferencias	Personal	Vinculadas a la cuenta; bajo riesgo.
Ubicación de los jugadores	Categoría especial: geolocalización	Exige informar tipo, finalidad, duración y destinatarios (Ley 19.628, art. 16 sexies); permite inferir domicilio y hábitos.
Fotogramas y fotos para publicar	Personal (incidental); no biométrico	Pueden captar manos, rostros o el hogar, pero no hay tratamiento que identifique a la persona (Ley 19.628, art. 16 ter): la IA solo reconoce cartas.
Colección, ofertas, transacciones, cupones	Personal; riesgo de sensible	Sumados, el valor de la colección y las compras podrían revelar la situación socioeconómica (Ley 19.628, art. 2 g); no se perfilan.
Tarjeta y referencia de pago	Personal (financiero)	La tarjeta solo la ve MercadoPago; la referencia se vincula a la transacción de un jugador (Ley 19.628, art. 2 f), pero no sirve fuera de MercadoPago.
Dirección IP	Personal	Identifica indirectamente al titular (Ley 19.628, art. 2 f); la app no la registra.
Datos de un menor de 18 años	Categoría especial: menores	Interés superior del menor y, bajo 14 años, consentimiento de los padres (Ley 19.628, art. 16 quáter); la app no pregunta la edad.

7. Finalidad y base de licitud

La Ley 19.628, art. 13, admite tratar datos sin consentimiento por, entre otras, una obligación legal (letra b), un contrato con el titular (letra c) o un interés legítimo (letra d). Se usó **contrato** cuando el dato es indispensable para el servicio pedido y **consentimiento** solo para lo opcional, porque la Ley 19.628, art. 12, destaca que no es libre el consentimiento exigido para algo que el servicio no requiere. Hoy la autorización debe "constar por escrito" (Ley 19.628 (texto vigente), art. 4); la Ley 19.628, art. 12, acepta un medio electrónico o un acto afirmativo inequívoco, como activar el 2FA en la app.

F1 — Registro y autenticación

Finalidad: crear y proteger la cuenta. **Base:** contrato (Ley 19.628, art. 13 c) para email, nombre, contraseña, tokens y correo de bienvenida: sin ellos no existe la cuenta solicitada. El **2FA**, en **consentimiento** (Ley 19.628, art. 12): es opcional, se activa con un acto afirmativo y se revoca desactivándolo, lo que borra el secreto.

F2 — Escaneo y publicación de cartas

Finalidad: identificar la carta y, si el jugador quiere, publicarla. **Fotogramas del escáner:** no hay tratamiento del responsable. Tratar es recolectar, procesar, almacenar, comunicar o usar datos (Ley 19.628, art. 2 o) por decisión del responsable (Ley 19.628, art. 2 n); los fotogramas se procesan en memoria en el teléfono del jugador y se descartan, sin que el responsable los obtenga ni almacene. Por eso no se les exige el consentimiento informado que sí se exige a la ubicación, que llega al servidor (F3); el permiso del sistema es un control del jugador sobre su dispositivo. Es protección desde el diseño (Ley 19.628, art. 14 quáter) y proporcionalidad (Ley 19.628, art. 3 c). **Foto publicada y datos de la carta: contrato** (Ley 19.628, art. 13 c): publicar es el servicio pedido y la foto muestra el estado real de la carta.

F3 — Búsqueda con ubicación

Finalidad: mostrar a los compradores la distancia a cada vendedor. **Base: consentimiento** (Ley 19.628, arts. 12 y 16 sexies). No puede ser contrato: la búsqueda funciona sin ubicación y exigirla implicaría presumir un consentimiento no libre (Ley 19.628, art. 12). Hoy se guarda la ubicación de **todo** jugador con sesión que abre el Bazaar, aunque solo hace falta la de quienes venden, lo que excede la proporcionalidad (Ley 19.628, art. 3 c); además solo existe el permiso genérico del sistema y no se puede dejar de compartir. Son brechas (sección 8).

F4 — Compraventa y pago

Finalidad: ejecutar la compraventa, cobrar y dejar respaldo. **Base: contrato** (Ley 19.628, art. 13 c) para crear la transacción, enviar a MercadoPago id, título y monto, y mandar el

comprobante: son pasos necesarios de la compraventa que el jugador inicia. **Conservación:** la plataforma no cobra comisión ni es parte de la compraventa, pero en los pagos con MercadoPago **el dinero entra a su cuenta** y lo recauda por cuenta del vendedor, por lo que queda en su contabilidad, que debe guardarse mientras el SII pueda revisar (DL 830, art. 17), hasta seis años (DL 830, art. 200). Se propone ese plazo como **obligación legal** (Ley 19.628, art. 13 b) solo para esos pagos, a confirmar (dudas abiertas). En efectivo la plataforma no recibe dinero: rige solo el contrato. La tarjeta la trata MercadoPago bajo su propio contrato. Al estar el servidor en EE.UU. hay **transferencia internacional**, que exige país adecuado o garantías contractuales con AWS (Ley 19.628, art. 27).

Otros tratamientos (fuera de los cuatro flujos)

Preferencias y cupones: contrato (Ley 19.628, art. 13 c): son ajustes y promociones que el propio jugador pide.

Dirección IP: interés legítimo (Ley 19.628, art. 13 d), ponderado. El interés (entregar y proteger el servicio) exige la IP y no hay alternativa menos intrusiva; la app no la guarda ni la cruza con la cuenta, y solo AWS la ve como encargado, lo que el jugador espera. Así no prevalece sobre sus derechos, aunque puede exigir ser informado (Ley 19.628, art. 13 d).

8. Conclusiones

Datos más críticos:

1. La **geolocalización** del vendedor, por ser una categoría especial y permitir inferir su domicilio.
2. Las **credenciales** (contraseña, secreto 2FA, tokens), porque su filtración permite suplantar al jugador.
3. El **historial de transacciones y la colección**, que juntos podrían revelar la situación socioeconómica.
4. Los datos de **posibles menores de edad**.

Medidas ya implementadas (Anexo B):

Contraseña con bcrypt; tokens de renovación con SHA-256; secreto 2FA y ubicación cifrados con AES-256-GCM (llave fuera de la base de datos); pago tokenizado; sesión, QR y avisos de pago firmados con HMAC; fotos en bucket privado. Esto va más allá de la "debida diligencia" que hoy exige la Ley 19.628 (texto vigente), art. 11, y apunta al deber de medidas de seguridad apropiadas del nuevo texto (Ley 19.628, art. 14 quinquies).

Riesgos y brechas identificadas:

- **Conservación indefinida:** sin cierre de cuenta ni limpieza periódica, contra la proporcionalidad (Ley 19.628, art. 3 c) y la supresión (Ley 19.628, art. 7). Propuesta: cierre de cuenta y tarea que aplique los plazos.

- **Ubicación:** consentimiento incompleto y se guarda también la de compradores (Ley 19.628, arts. 3 c, 12 y 16 sexies). Propuesta: guardarla solo para vendedores con publicaciones, pantalla explicativa, interruptor que borre las coordenadas y redondeo.
- **Sin verificación de edad** (Ley 19.628, art. 16 quáter). Propuesta: pedir la edad y exigir autorización parental bajo 14 años.
- **Sin política de privacidad** (Ley 19.628, art. 14 ter); **transferencia a AWS (EE.UU.)** sin garantías documentadas (Ley 19.628, art. 27); **tránsito sin TLS**; tokens en almacenamiento local.

Definiciones por tomar:

- a. Si el valor agregado de una colección es "situación socioeconómica" (Ley 19.628, art. 2 g).
- b. Cómo acreditar la transferencia a AWS sin lista oficial de países adecuados.
- c. Sí MercadoPago es responsable independiente o encargado.
- d. Qué edad mínima exigir para llevar a cabo el registro de usuario.
- e. Si, al recaudar por MercadoPago sin comisión, la plataforma es mandataria del vendedor y le aplica el plazo tributario de 6 años.

9. Referencias

- Ley 19.628, sobre protección de la vida privada (texto vigente hasta el 30-11-2026), arts. 4 y 11. <https://www.bcn.cl/leychile/navegar?idNorma=141599>
- Ley 21.719 (D.O. 13-12-2024; vigencia 01-12-2026): artículo primero transitorio y, de la Ley 19.628 en su nuevo texto, arts. 2 (f, g, n, o), 3, 7, 12, 13, 14 ter, 14 quáter, 14 quinquies, 16 ter, 16 quáter, 16 sexies y 27. <https://www.bcn.cl/leychile/navegar?idNorma=1209272>
- Decreto Ley 830, Código Tributario, artículos 17 y 200. <https://www.bcn.cl/leychile/navegar?idNorma=6374>
- Repositorio MTG Companion (código, Actividades N°1 y N°2, evidencias): https://github.com/inzenfenix/MTGCompanion_TCG

10. Anexos

Anexo A — Actividad N°1: Mapeo de actores, datos y riesgos CIA

Actor	Dato que maneja	Atributo CIA en riesgo	Por qué
Cliente, comprador o vendedor	Foto del producto capturada por la cámara	Confidencialidad	El frontend procesa la imagen en el dispositivo, pero puede quedar en caché local, exponiendo el entorno del cliente sin cifrado adicional.
Cliente	Credenciales de acceso, correo y contraseña	Confidencialidad	El frontend envía las credenciales al backend por la red; sin HTTPS forzado en producción, quedan expuestas a interceptación.
Cliente	Token de sesión activa	Confidencialidad	El frontend guarda el token localmente, si un atacante inyecta código malicioso puede robarlo y suplantar al cliente ante el backend.
Cliente	Token de renovación de sesión	Integridad	El backend lo valida y rota en cada uso, pero si el frontend no lo consume bien, un token filtrado sigue vigente por semanas.
Cliente	Segundo factor de autenticación	Confidencialidad	Viaja entre frontend y backend al activarlo, interceptarlo en tránsito compromete la doble verificación de la cuenta en producción.
Administrador del sistema	Credenciales de la infraestructura en la nube	Confidencialidad	En producción dan acceso a servidores, base de datos y almacenamiento reales; una filtración compromete todo el servicio activo.
Backend	Secretos de configuración de pagos y sesión	Confidencialidad	Si se filtran en producción, comprometen pagos reales de clientes y la validez de todas las sesiones activas del sistema.

Actor	Dato que maneja	Atributo CIA en riesgo	Por qué
Backend, base de datos	Contraseña de usuario	Confidencialidad	Se guarda hasheada, pero una filtración masiva de la base en producción permite fuerza bruta offline sobre miles de clientes.
Backend, base de datos	Precio estimado del producto	Integridad	Lo calcula el frontend con IA embebida y lo envía tal cual; en producción un cliente podría alterar el valor antes de publicarlo.
Backend, API externa de pagos	Notificación de pago confirmado	Integridad	El backend valida la firma del proveedor externo, pero un secreto filtrado permitiría falsificar pagos entre clientes reales.
Servicio de almacenamiento de archivos	Fotos subidas por los clientes	Confidencialidad	Si el almacenamiento en producción queda mal configurado como público, expone fotos de miles de clientes reales.
Servicio de almacenamiento de archivos	Fotos subidas por los clientes	Disponibilidad	Una sola instancia sin redundancia deja sin servicio de fotos a todos los clientes durante una caída en producción.
Base de datos	Cuentas, productos y transacciones de todos los clientes	Disponibilidad	Sin redundancia ni respaldo automático, una caída en producción interrumpe el servicio completo para todos los clientes.
Proveedor de correo transaccional	Correos de bienvenida y comprobantes de pago	Confidencialidad	En producción debe ser un proveedor real y autenticado; uno mal configurado permitiría leer correos de cualquier cliente.
API externa de catálogo	Información y precio de referencia del producto	Disponibilidad	El frontend depende de ella en tiempo real para identificar productos; si cae en producción, el cliente no puede escanear nada.

Actor	Dato que maneja	Atributo CIA en riesgo	Por qué
API externa de catálogo	Resultados devueltos al buscar un producto	Integridad	Un cambio no controlado del proveedor externo puede alterar resultados de búsqueda sin que backend o frontend lo detecten.
Modelo de IA embebido en la app	Resultado de identificación, condición y precio	Integridad	Corre en el dispositivo del cliente sin firma ni verificación del backend; nada impide alterar el resultado antes de enviarlo.
Contraparte de una transacción	Código de verificación de la compraventa	Confidencialidad	Si el cliente lo comparte fuera de la app, en producción un tercero podría intentar interferir en una transacción real.
Backend	Probabilidad de premio en promociones internas	Integridad	Se valida y canjea en el backend, no en el frontend; evita que un cliente en producción se autoasigne un premio no autorizado.
Backend	Comunicación interna entre módulos de cuentas, pagos y catálogo	Integridad	Si un módulo interno no valida permisos antes de llamar a otro, un fallo puede exponer o alterar datos de otro cliente.
Cliente	Composición completa de su colección o inventario	Confidencialidad	En producción revela el valor total de los bienes de un cliente real, dato sensible ante robo de cuenta o ingeniería social.
Cliente	Acceso a la cámara del dispositivo	Disponibilidad	Si el cliente niega el permiso o el hardware falla, el flujo de escaneo y venta queda inutilizable sin alternativa manual.
Infraestructura en la nube	Estado y configuración de los servidores desplegados	Confidencialidad	Contiene metadata de todos los recursos productivos; expuesta, sería un mapa completo para atacar el servicio real.

Anexo B — Actividad N°2: Cifrado, hashing y tokenización

Cuadro del Item I de la Actividad N°2. La implementación (Item II), con su código fuente y evidencias, está en docs/security/ACTIVIDAD_2.md del repositorio; en la columna Evidencia, 01 a 05 son los archivos de docs/security/evidencia/.

Campo	Necesidad	Elección	Criterio técnico	Implementación	Evidencia
Contraseña (User.passwordHash)	Solo comparar en el login; nunca recuperarla.	Hashing (bcrypt)	Dato de baja entropía → hash lento y con sal contra fuerza bruta offline si se filtra la BD. Costo 12, sal aleatoria por usuario embebida en el hash.	bcryptjs en UserService.register() / validateCredentials() (users.service.ts)	04 paso 2: la BD guarda \$2b\$12\$...
Token de renovación de sesión (RefreshToken.tokenHash)	Solo verificar que existe y no fue usado.	Hashing (SHA-256)	Aleatorio de 512 bits y de un solo uso → alta entropía, basta un hash rápido sin sal. Se rota en cada uso.	node:crypto en AuthService.hashToken() (auth.service.ts)	02: auth-refresh.e2e-spec (rotación, reuso rechazado)
Segundo factor (UserSettings.twoFactorSecret, secreto TOTP)	Recuperar el secreto original para calcular el código de 6 dígitos en cada login.	Cifrado simétrico (AES-256-GCM)	Un hash no sirve (TOTP necesita el secreto). GCM = cifrado autenticado : si alguien altera el valor, el descifrado falla. IV aleatorio de 12 bytes por escritura; prefijo de versión de llave para rotarla.	FieldEncryptionService usado en PrismaUserRepository (cifra al escribir, descifra al leer)	01 · 03 · 04 pasos 3–6 y 10

Campo	Necesidad	Elección	Criterio técnico	Implementación	Evidencia
Ubicación del jugador (UserSettings.lastLat / lastLng)	Recuperar para calcular la distancia al vendedor en la búsqueda. Dato personal (Ley 21.719).	Cifrado simétrico (AES-256-GCM)	La distancia se calcula en el backend (Node), así que se puede descifrar ahí; las coordenadas nunca vuelven al cliente, solo distanceKm. Misma llave que el 2FA.	Migración Float → TEXT (migration.sql); cifrado en PrismaUserRepository, descifrado en PrismaCardRepository	03 antes/después · 04 pasos 7 y 9
Datos de pago (tarjeta)	No tocarlos nunca; solo referenciar el pago.	Tokenización	MercadoPago es la bóveda: la tarjeta se ingresa en su checkout y el sistema solo guarda paymentRef (el token) para consultar el estado.	SDK oficial mercadopago (mercadopago-payment.provider.ts); Transaction solo tiene paymentRef en schema.prisma	schema.prisma: ninguna columna de tarjeta; 02 flujos de pago
Sesión (access token JWT)	Que nadie pueda fabricar un token válido (integridad).	Firma (HMAC-SHA256)	Lo importante no es ocultarlo sino verificar quién lo emitió. El secreto de firma ya no tiene valor por defecto en producción.	@nestjs/jwt HS256; JWT_SECRET desde AWS Secrets Manager; assertProductionSecrets()	04 paso 6 · 05 paso 5
Código de verificación de la compraventa (QR)	Que el QR apunte a una publicación real y no se pueda falsificar.	Firma (HMAC-SHA256)	Token firmado con typ: 'listing' y vencimiento de 3 minutos; el backend valida la firma al escanearlo.	listing-token.ts	02: listing-token.e2e-spec

Campo	Necesidad	Elección	Criterio técnico	Implementación	Evidencia
Email y nombre visible (User.email, displayName)	El email se busca por igualdad en el login; el nombre se muestra a la contraparte.	Sin cifrado de campo	Cifrar con IV aleatorio impediría buscar por email (@unique); el nombre es público por diseño. Se protegen en tránsito (TLS) y en reposo a nivel de disco.	—	Justificación en Cifrado_Camp OS.md §2